Lecture 2 ความตระหนักรู้ด้านความมั่นคงทางไซเบอร์ (Cybersecurity awareness)

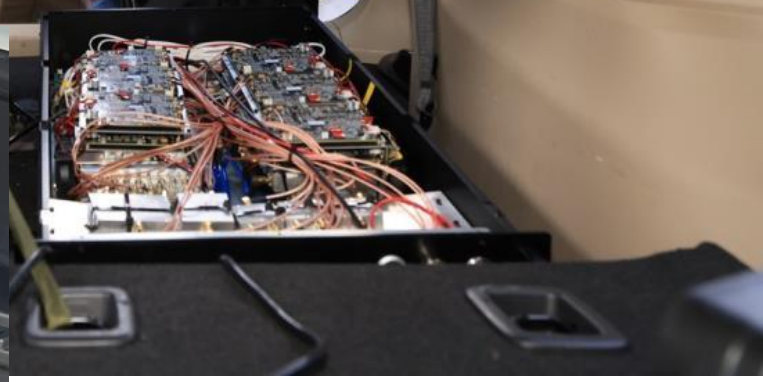
ทสวด191 พื้นฐานจริยธรรมทางคอมพิวเตอร์

ITDS191 Fundamentals of Computer Ethics

Image source: https://bit.ly/3gZSocK

Operation Sukhumvit จับสถานีฐานเถื่อน False Base Station
AIS
CCIB
G-BIZ MGRONLINE
AIS ร่วมตำรวจ จับมิจฉาชีพ
หลอกส่ง SMS แนบลิงก์ จากเครื่องส่งปลอม

AIS



Top 10 Most Common Passwords

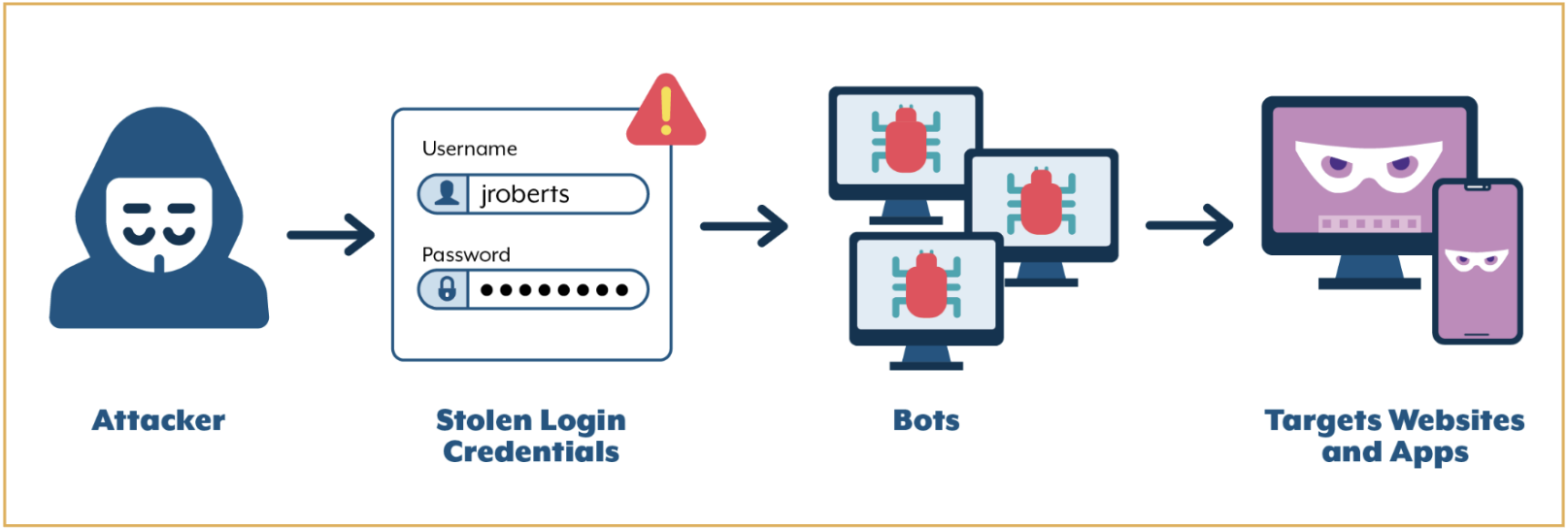
Rank	2011[6]	2012[7]	2013[8]	2014[9]	2015[10]	2016[5]	2017[11]	2018[12]	2019[13]
1	password	password	123456	123456	123456	123456	123456	123456	123456
2	123456	123456	password	password	password	password	password	password	123456789
3	12345678	12345678	12345678	12345	12345678	12345	12345678	123456789	qwerty
4	qwerty	abc123	qwerty	12345678	qwerty	12345678	qwerty	12345678	password
5	abc123	qwerty	abc123	qwerty	12345	football	12345	12345	1234567
6	monkey	monkey	123456789	123456789	123456789	qwerty	123456789	111111	12345678
7	1234567	letmein	111111	1234	football	1234567890	letmein	1234567	12345
8	letmein	dragon	1234567	baseball	1234	1234567	1234567	sunshine	iloveyou
9	trustno1	111111	iloveyou	dragon	1234567	princess	football	qwerty	111111
10	dragon	baseball	adobe123[a]	football	baseball	1234	iloveyou	iloveyou	123123

https://en.wikipedia.org/wiki/List_of_the_most_common_passwords

Password Hacking and Cracking

- Guess
- Phishing
- Social Engineering
- Malware
- Shoulder Surfing
- Keylogger
- Brute force Attack
- Dictionary Attack
- Rainbow Table Attack
- Network Analyzers
- Fake wireless access point

Credential Stuffing



https://ag.ny.gov/sites/default/files/businessguide-credentialstuffingattacks.pdf

New NIST Password Guidelines

- Memorized secret with sufficient complexity !
- Password length is overestimated, **8 character minimum** is fine (and at least 64 characters as an upper limit).
- Password complexity is more of a hindrance, it should be allowed but not enforced.
- Password must not be a common word, as found in a typical wordlist or dictionary.
- Password must be checked against a corpus of breached or pwned passwords.
- Password rotation should not be enforced. Users should change their password if they are compromised (or suspected to have been compromised).
- Implement a sensible limit for the number of online password attempts.

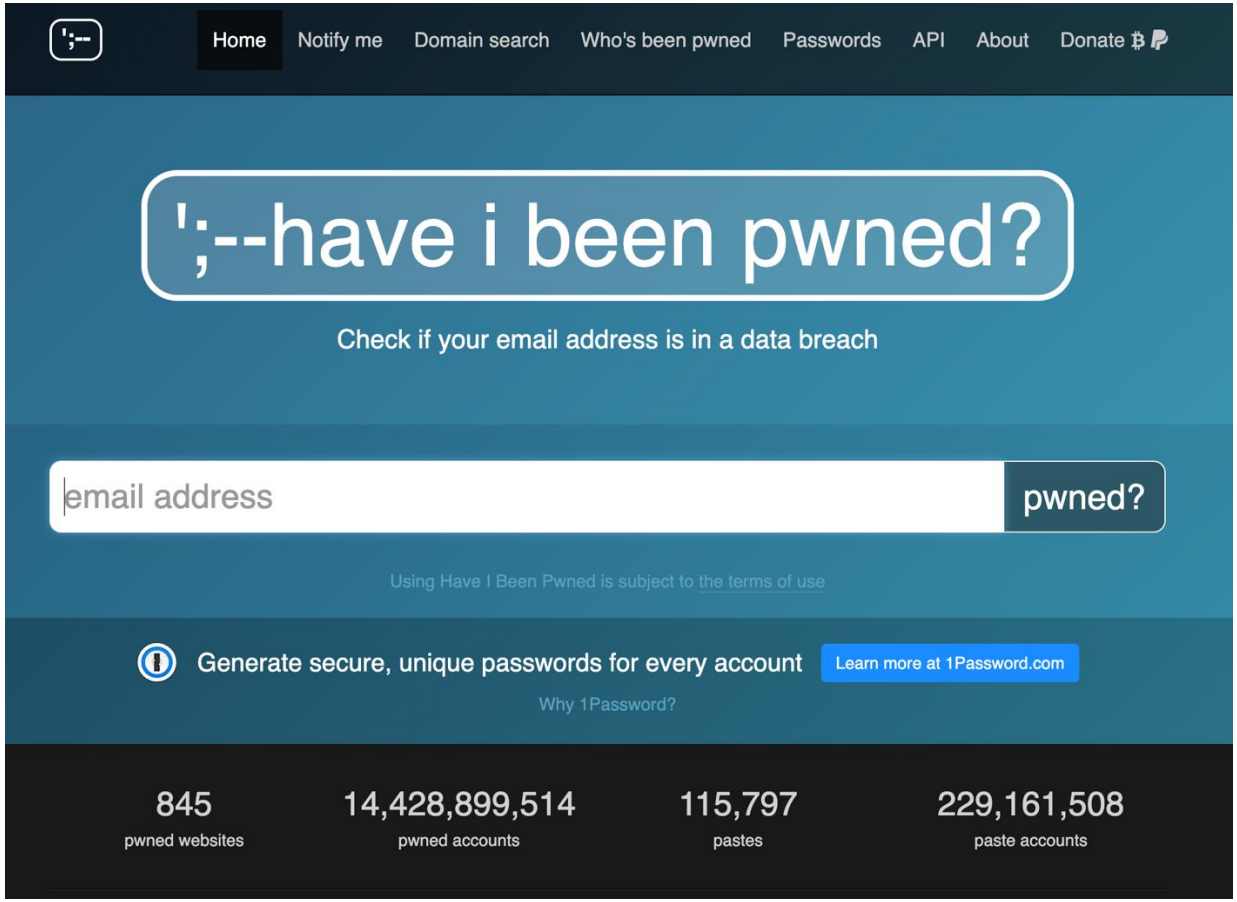
https://pages.nist.gov/800-63-3/sp800-63b.html
https://safepass.me/2021/03/11/complying-with-nist-password-guidelines-in-2021/

การพิสูจน์ตัวตนแบบหลายปัจจัย (MFA)

Bad: Password and....	**Good:** Password and....	**Better:** Password and....	**Best:** Password and....
123456 matheus password abcdef 05/03/1989	SMS Voice	Microsoft Authenticator Software Tokens OTP Hardware Tokens OTP	Windows Hello Microsoft Authenticator FIDO2 Security Key

password ของอีเมล์คุณเคยโดนแฮ็กไปหรือยัง

https://haveibeenpwned.com/



Cybersecurity

Cybersecurity หรือ ความมั่นคงปลอดภัยทางไซเบอร์

การนำเครื่องมือทางด้านเทคโนโลยี และกระบวนการที่รวมถึง วิธีการปฏิบัติที่ถูกออกแบบไว้เพื่อป้องกันและรับมือที่อาจจะถูกโจมตีเข้ามายังอุปกรณ์เครือข่าย, โครงสร้างพื้นฐานทางสารสนเทศ, ระบบหรือโปรแกรมที่อาจจะเกิดความเสียหายจากการที่ถูกเข้าถึงจากบุคคลที่สามโดยไม่ได้รับอนุญาต

กฎหมายและมาตรฐานที่เกี่ยวข้อง

- พ.ร.บ การรักษาความมั่นคงปลอดภัยไซเบอร์ พ.ศ. 2562
- พ.ร.บ ว่าด้วยการกระทำความผิดเกี่ยวกับคอมพิวเตอร์ พ.ศ. 2560
- พ.ร.บ คุ้มครองข้อมูลส่วนบุคคล
- มาตรฐานด้านความปลอดภัย ISO 27001

ความรู้พื้นฐานของ Cybersecurity

https://medium.com/@jashvanth/cia-1a13d378c8e5

ความรู้พื้นฐานของ Cybersecurity

Confidentiality หรือ การรักษาความลับของข้อมูล

การปกปิดข้อมูลหรือทรัพยากร ที่มีความจำเป็นต้องเก็บรักษาความลับของข้อมูลที่เกิดจากการใช้คอมพิวเตอร์ในด้านที่ละเอียดอ่อน

เช่น ข้อมูลส่วนเงินเดือนของพนักงานในบริษัท จัดเป็นความลับสูงสุด ผู้ที่สามารถเข้าถึงได้ คือ ผู้จัดการส่วนทรัพยากรบุคคลเท่านั้น

ความรู้พื้นฐานของ Cybersecurity

Integrity หรือการรักษาความถูกต้องของข้อมูล

การรักษาความถูกต้องของข้อมูลให้มี ความถูกต้องอย่างต่อเนื่อง ความน่าเชื่อถือของข้อมูลหรือทรัพยากร

เช่น การป้องกันการแก้ไขตัวเลขเงินเดือนของพนักงานที่ไม่ได้ผ่านการอนุมัติ

ความรู้พื้นฐานของ Cybersecurity

Availability หรือ ความพร้อมใช้งานของข้อมูล

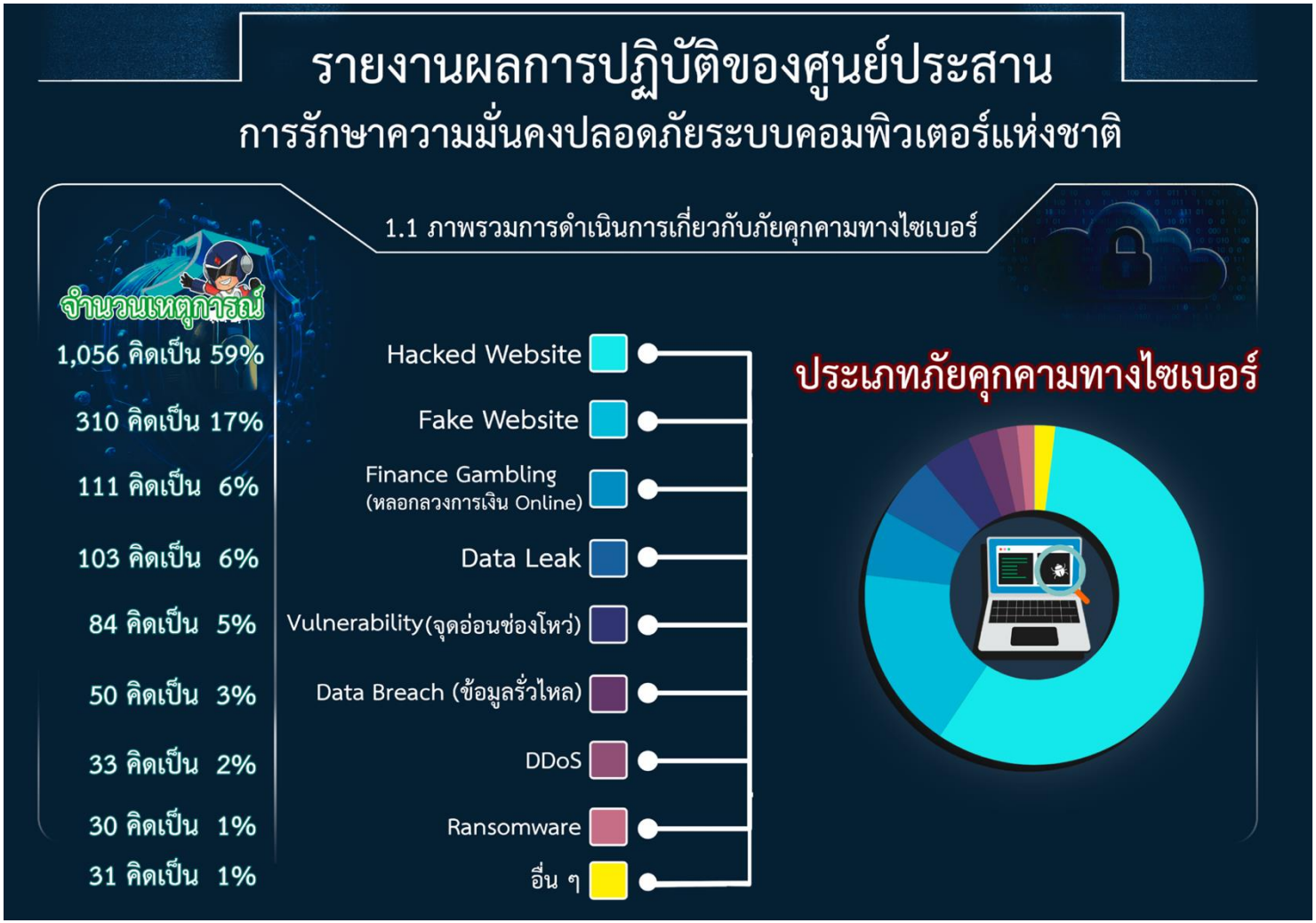
การที่ข้อมูลพร้อมให้เข้าถึงใช้งานได้ตลอดเวลา รักษาความต่อเนื่องในการให้บริการข้อมูล

เช่น ข้อมูลเงินเดือนของพนักงานสามารถถูกเรียกดูได้เมื่อต้องการ

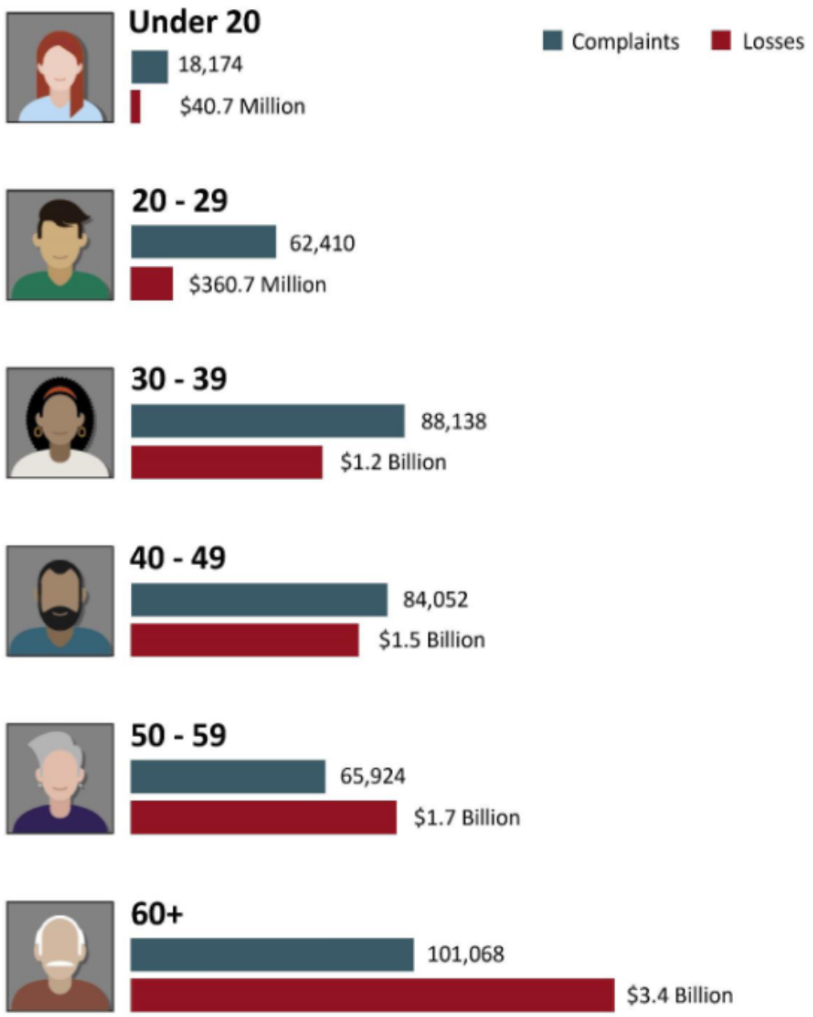
รูปแบบภัยคุกคามของ Cybersecurity

- Malware
- Web-based attacks
- Phishing
- Spam
- DDoS
- Data breach
- Insider threat
- Botnets
- Ransomware
- Cryptojacking

สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ (สกมช.) or NCSA



2023 – COMPLAINANTS BY AGE GROUP



ไวรัส (Virus)

- คือโปรแกรมคอมพิวเตอร์ที่ถูกออกแบบมาให้แพร่กระจายตัวเองจากไฟล์หนึ่งไปยัง ไฟล์อื่น ๆ ภายในเครื่องคอมพิวเตอร์
- ไวรัสจะไม่สามารถแพร่กระจายไปยังเครื่องอื่น ๆ ด้วยตัวเอง ต้องอาศัยไฟล์พาหะ เช่น อีเมล์ หรือ นำเอาflash drive ที่ติดไวรัสจากเครื่องหนึ่งไปใช้กับอีกเครื่องหนึ่ง
- สามารถเผยแพร่ไปสู่ระบบคอมพิวเตอร์อื่น ๆ ได้ เมื่อได้รับการรัน หรือ execute
- ไวรัสบางชนิดแนบตัวเองกับไฟล์โปรแกรม เช่น .com .exe

หนอน (Worms)

- Worm เป็นโปรแกรมที่ถูกออกแบบมาให้สามารถคัดลอกและแพร่กระจายตัวเองได้ จากเครื่องคอมพิวเตอร์เครื่องหนึ่งไปยังอีกเครื่องหนึ่ง โดยอาศัยระบบเครือข่าย หรือ ระบบแชร์ไฟล์
- ลักษณะอาการเครื่องที่ติด เช่น เครื่องทำงานช้าลง ไฟล์ข้อมูลหรือโปรแกรมเพิ่มขึ้น หรือหายไป ขนาดของหน่วยความจำลดน้อยลง

โทรจัน (Trojans)

- โปรแกรมเหล่านี้ถูกพัฒนาให้ดูเหมือนโปรแกรมทั่วไปที่มีประโยชน์ เพื่อดึงดูดให้ผู้ใช้งานเรียกใช้งาน
- เมื่อไฟล์ดังกล่าวถูกเปิดใช้งาน โทรจันจะเริ่มทำงานและสร้างช่องทางให้ผู้บุกรุกสามารถเข้าถึงระบบได้ (backdoor)
- ถูกออกแบบให้แอบแฝงอยู่ในระบบเพื่อดักจับข้อมูลสำคัญ เช่น รหัสผ่าน และส่งข้อมูลกลับไปยังผู้ไม่หวังดี ซึ่งสามารถใช้ข้อมูลเหล่านี้ในการโจมตีระบบในอนาคต

Botnet

- เป็นกลุ่มของอุปกรณ์ที่ติดมัลแวร์และถูกเปลี่ยนให้ทำหน้าที่เป็นบอต (Bot) ซึ่งอาจรวมถึงคอมพิวเตอร์ เราเตอร์ หรืออุปกรณ์ IoT โดยรอรับคำสั่งจากแฮกเกอร์
- มีการกำหนดบอตตัวหลัก (หัวหน้า) เพื่อออกคำสั่งและรับคำสั่งจากแฮกเกอร์ โดยนำเครือข่าย Botnet ไปใช้ในแคมเปญการโจมตีขนาดใหญ่ เช่น การโจมตีแบบ DDoS หรือการส่งสแปม

Spyware, Adware

- Spyware เป็นโปรแกรมที่แอบติดตามพฤติกรรมผู้ใช้ บันทึกข้อมูล และอาจขโมยข้อมูลส่วนตัวโดยไม่รู้ตัว เพื่อนำส่งไปยังผู้โจมตี เช่น การเก็บข้อมูลเว็บที่เข้าชมบ่อยหรือข้อมูลระบบคอมพิวเตอร์
- Adware เป็นโปรแกรมที่สอดส่องการใช้งานและแสดงโฆษณา เช่น เปิดหน้าเว็บป๊อปอัปอัตโนมัติ

มัลแวร์เรียกค่าไถ่ (Ransomware)

- แพร่กระจายผ่านเว็บไซต์และไฟล์แนบอีเมล โดยเข้ารหัสไฟล์หรือล็อกเครื่องจนไม่สามารถใช้งานได้ และผู้ใช้ต้องจ่ายค่าไถ่ให้แฮกเกอร์เพื่อปลดล็อกหรือถอดรหัสข้อมูล.

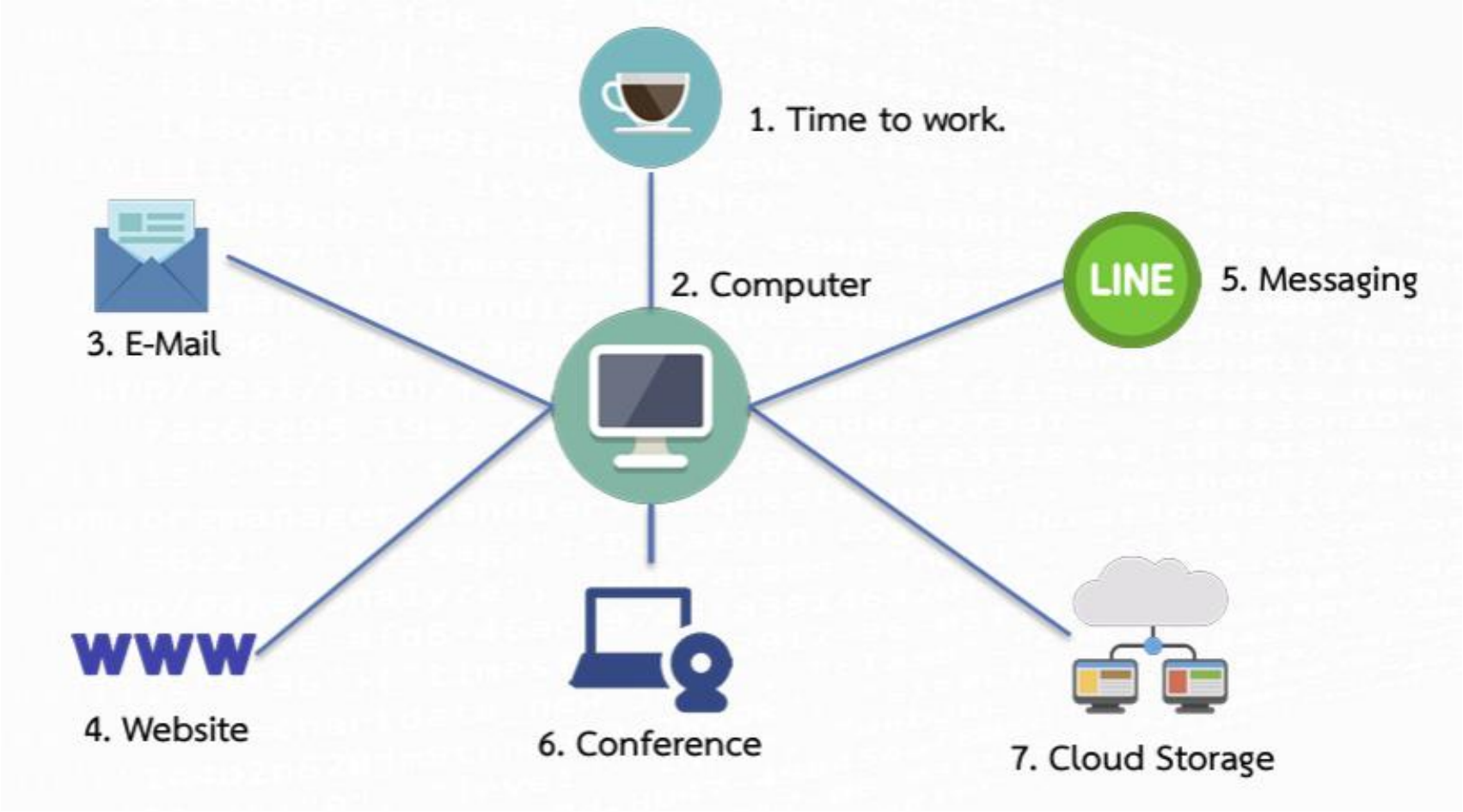
ความตระหนักรู้เรื่องความปลอดภัย (Cybersecurity Awareness)

ความตระหนักรู้เรื่องความปลอดภัย คือ ความรู้ ความเข้าใจ และทัศนคติ ที่สมาชิกขององค์กรมีด้านการรักษาความมั่นคงปลอดภัย การคุ้มครองป้องกันภัยการโจมตี อาชญากรรม และความผิดพลาดต่าง ๆ ที่อาจเกิดขึ้น

ทำไมความตระหนักรู้เรื่องความปลอดภัยจึงสำคัญ

- ความตระหนักรู้เรื่องความปลอดภัย เป็น**ทักษะ**ที่สำคัญในการควบคุมตัวเอง ไม่ให้ตกเป็นเหยื่อของการฉ้อโกงทางอินเทอร์เน็ต การแฮ็ก หรือภัยคุกคามทางไซเบอร์อื่นๆ
- ตัวอย่างทักษะที่ผู้ผ่านการฝึกอบรมเรื่องความตระหนักรู้เรื่องความปลอดภัย เช่น
  - รู้ว่าอย่าคลิกลิงก์ที่น่าสงสัยในอีเมล หรือโซเชียลมีเดีย
  - รู้การสแกนไฟล์ขาเข้าทั้งหมดเพื่อหามัลแวร์: อีเมล, ไดรฟ์ USB
  - รู้จักรายงานกิจกรรมแปลกๆที่อาจมีความเสี่ยง (เช่น การตรวจสอบสิทธิ์แบบสองปัจจัยไม่ทำงาน)

ความตระหนักรู้ด้าน Cybersecurity



ความตระหนักรู้ด้าน Cybersecurity

Position	Password	Number of users	Time to crack it	Times exposed
1. ↑ (2)	123456	2,543,285	Less than a second	23,597,311
2. ↑ (3)	123456789	961,435	Less than a second	7,870,694
3. (new)	picture1	371,612	3 Hours	11,190
4. ↑ (5)	password	360,467	Less than a second	3,759,315
5. ↑ (6)	12345678	322,187	Less than a second	2,944,615
6. ↑ (17)	111111	230,507	Less than a second	3,124,368
7. ↑ (18)	123123	189,327	Less than a second	2,238,694
8. ↓ (1)	12345	188,268	Less than a second	2,389,787
9. ↑ (11)	1234567890	171,724	Less than a second	2,264,884
10. (new)	senha	167,728	10 Seconds	8,213
11. ↑ (12)	1234567	165,909	Less than a second	2,516,606

ความตระหนักรู้ด้าน Cybersecurity

Tr: ประกาศล่าสุด: อีเมลนี้แจ้งให้คุณทราบว่าการจัดส่งของคุณยังอยู่ระหว่างดำเนินการ

จาก: บริษัท ไปรษณีย์ไทย จำกัด

ถึง

สวัสดี,

ไม่สามารถจัดส่งพัสดุของคุณในวันที่ 18.04.2021 เนื่องจากไม่มีการชำระภาษีศุลกากร (3.59 BATH)

ร้านค้า: ไปรษณีย์ไทย
อ้างอิง: TH065038305
จำนวน: 3.59 BATH
กำหนดจัดส่งระหว่าง: 19.04.2021 - 21.04.2021

- เพื่อยืนยันการจัดส่งพัสดุของคุณคลิกที่นี่

ขอขอบคุณสำหรับความไว้วางใจของคุณ,

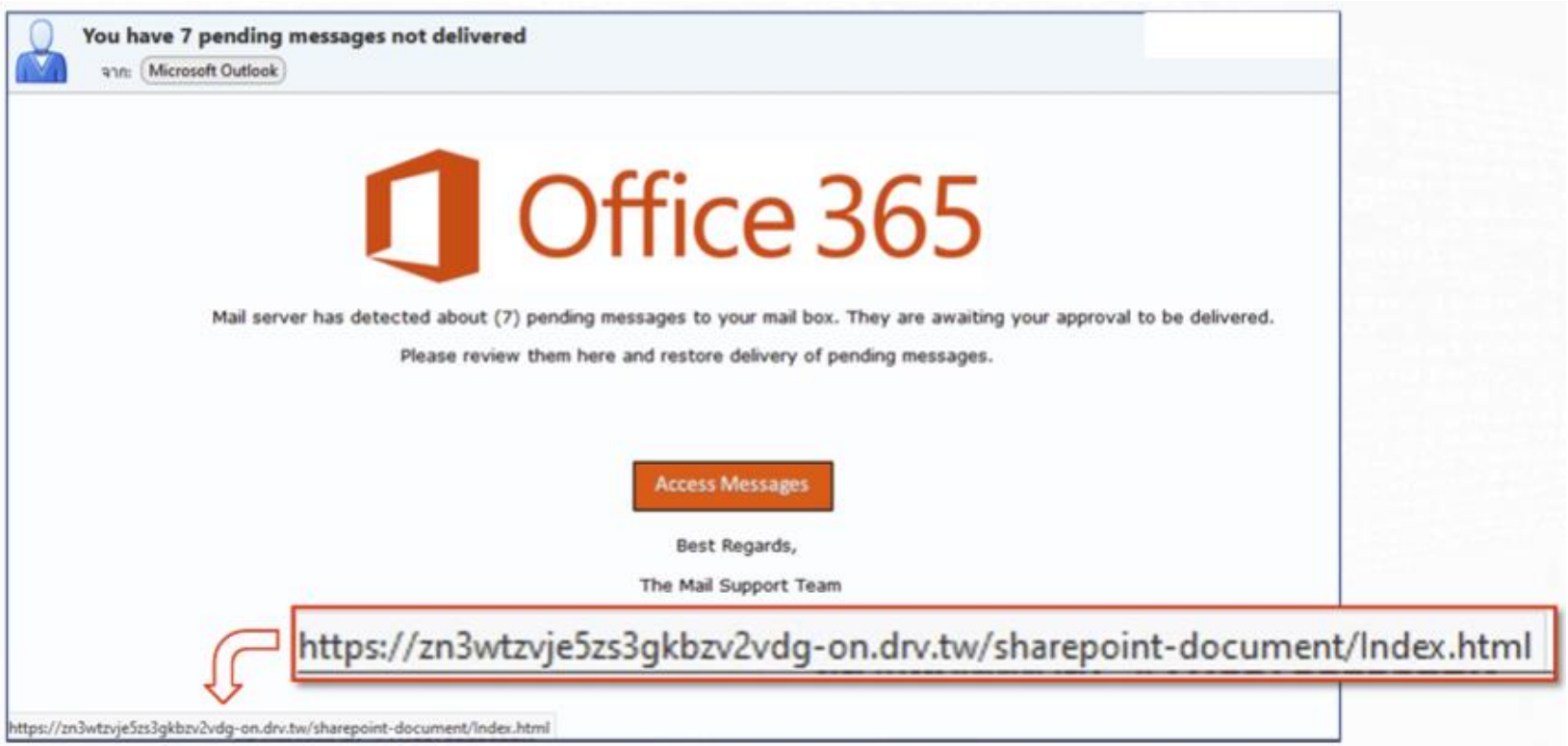
ขอแสดงความนับถือ
ฝ่ายบริการลูกค้าของไปรษณีย์ไทย

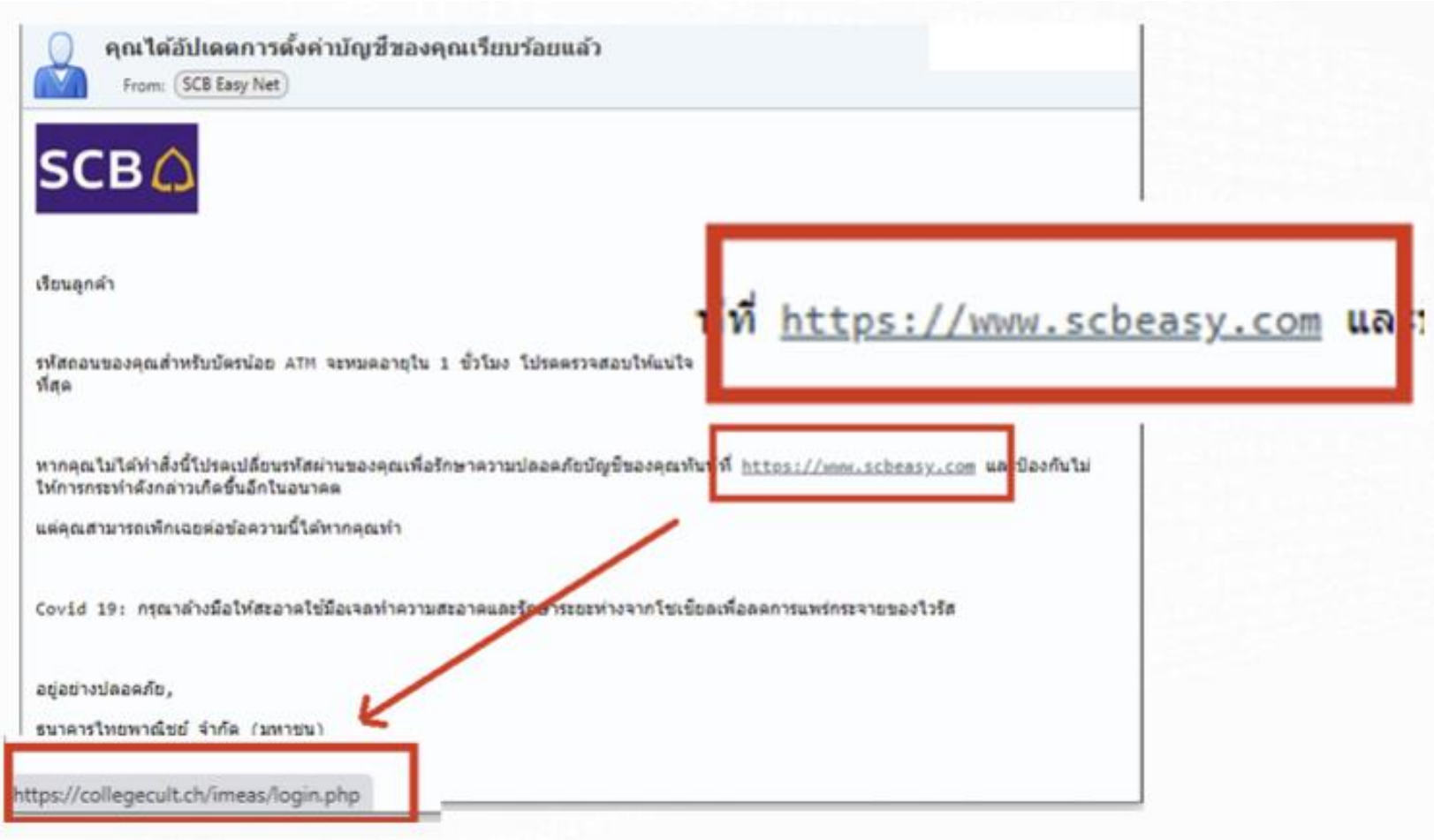
ข้อตกลงการให้บริการ

บริษัท ไปรษณีย์ไทย จำกัด (ปณท) ขอแจ้งนโยบายการให้บริการเพื่อให้ยอมรับและถือเป็นข้อตกลงเพื่อสร้างความเข้าใจเกี่ยวกับการใช้บริการเว็บไซต์ ดังนี้
1. ก่อนใช้บริการ ผู้ใช้บริการจะต้องยอมรับนโยบายการให้บริการนี้ นโยบายการให้บริการสามารถเปลี่ยนแปลงได้ตลอดเวลา โดยไม่ต้องมีการแจ้งล่วงหน้า
2. หากผู้ใช้บริการประสงค์จะสมัครเป็นสมาชิก สามารถทำได้โดยกดปุ่ม "สมัครสมาชิก" และกรอกข้อมูลต่าง ๆ ของท่านลงในแบบฟอร์มสมัครสมาชิก โดยที่ไม่ต้องเสียค่าธรรมเนียมหรือค่าแรกเข้าแต่อย่างใด หลังจาก ปณท ได้รับใบสมัครที่กรอกข้อความครบถ้วนแล้ว ผู้ใช้บริการจะสามารถใช้บริการใด ๆ ของ ได้ทันที
3. ระยะเวลาการเป็นสมาชิก ให้ถือว่ามีผลบังคับไปจนกว่าผู้ใช้บริการจะหมดเงื่อนไขเป็นสมาชิก หรือ ปณท ยกเลิกรับเนื่องจากผู้ใช้บริการไม่ปฏิบัติหรือปฏิบัติผิดข้อกำหนดของ
4. ผู้ใช้บริการจะต้องรับผิดชอบต่อ ชื่อผู้ใช้งาน และรหัสผ่าน ... นอกจากนี้ผู้ใช้บริการจะต้องรับผิดชอบต่อกิจกรรมต่าง ๆ ที่เกิดขึ้นจากการใช้ ชื่อผู้ใช้งาน และรหัสผ่าน ... ผู้ใช้บริการจะต้องรับผิดชอบในพฤติกรรมที่เกิดขึ้นจากการใช้ ชื่อผู้ใช้งาน และรหัสผ่านของบุคคลอื่น ทั้งนี้ ... ในการยกเลิกชื่อผู้ใช้งานทันทีหากผู้ใช้บริการฝ่าฝืนกฎ

https://ems-thpost.com/th58

https://ems-thpost.com/th58


You have 7 pending messages not delivered
จาก: Microsoft Outlook
Office 365
Mail server has detected about (7) pending messages to your mail box. They are awaiting your approval to be delivered.
Please review them here and restore delivery of pending messages.
Access Messages
Best Regards,
The Mail Support Team
https://zn3wtzvje5zs3gkbzv2vdg-on.drv.tw/sharepoint-document/Index.html
https://zn3wtzvje5zs3gkbzv2vdg-on.drv.tw/sharepoint-document/Index.html



คุณได้อัปเดตการตั้งค่าบัญชีของคุณเรียบร้อยแล้ว

From: SCB Easy Net

SCB

เรียนลูกค้า

รหัสถอนของคุณสำหรับบัตรน้อย ATM จะหมดอายุใน 1 ชั่วโมง โปรดตรวจสอบให้แน่ใจที่สุด

หากคุณไม่ได้ทำสิ่งนี้โปรดเปลี่ยนรหัสผ่านของคุณเพื่อรักษาความปลอดภัยบัญชีของคุณทันทีที่ https://www.scbeasy.com และป้องกันไม่ให้การกระทำดังกล่าวเกิดขึ้นอีกในอนาคต

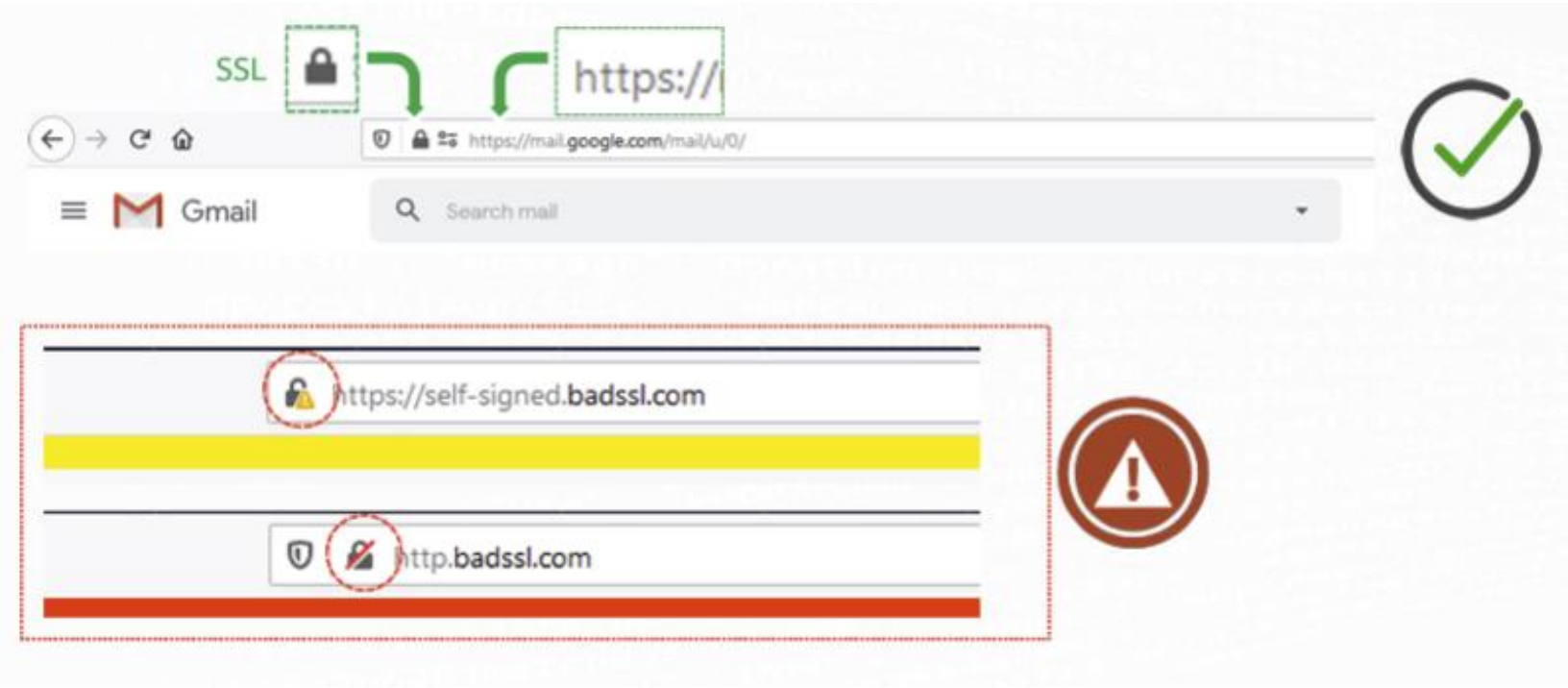
แต่คุณสามารถเพิกเฉยต่อข้อความนี้ได้หากคุณทำ

Covid 19: กรุณาล้างมือให้สะอาดใช้มือเจลทำความสะอาดและรักษาระยะห่างจากโซเชียลเพื่อลดการแพร่กระจายของไวรัส

อยู่อย่างปลอดภัย,

ธนาคารไทยพาณิชย์ จำกัด (มหาชน)

https://collegecult.ch/imeas/login.php


SSL
https://
https://mail.google.com/mail/u/0/
Gmail
Search mail
https://self-signed.badssl.com
http.badssl.com

Version 9.4.35 may request access to

Camera

- take pictures and videos

Location

- access precise location only in the foreground
- access approximate location (network-based) only in the foreground

Microphone

- record audio

Phone

- read phone status and identity

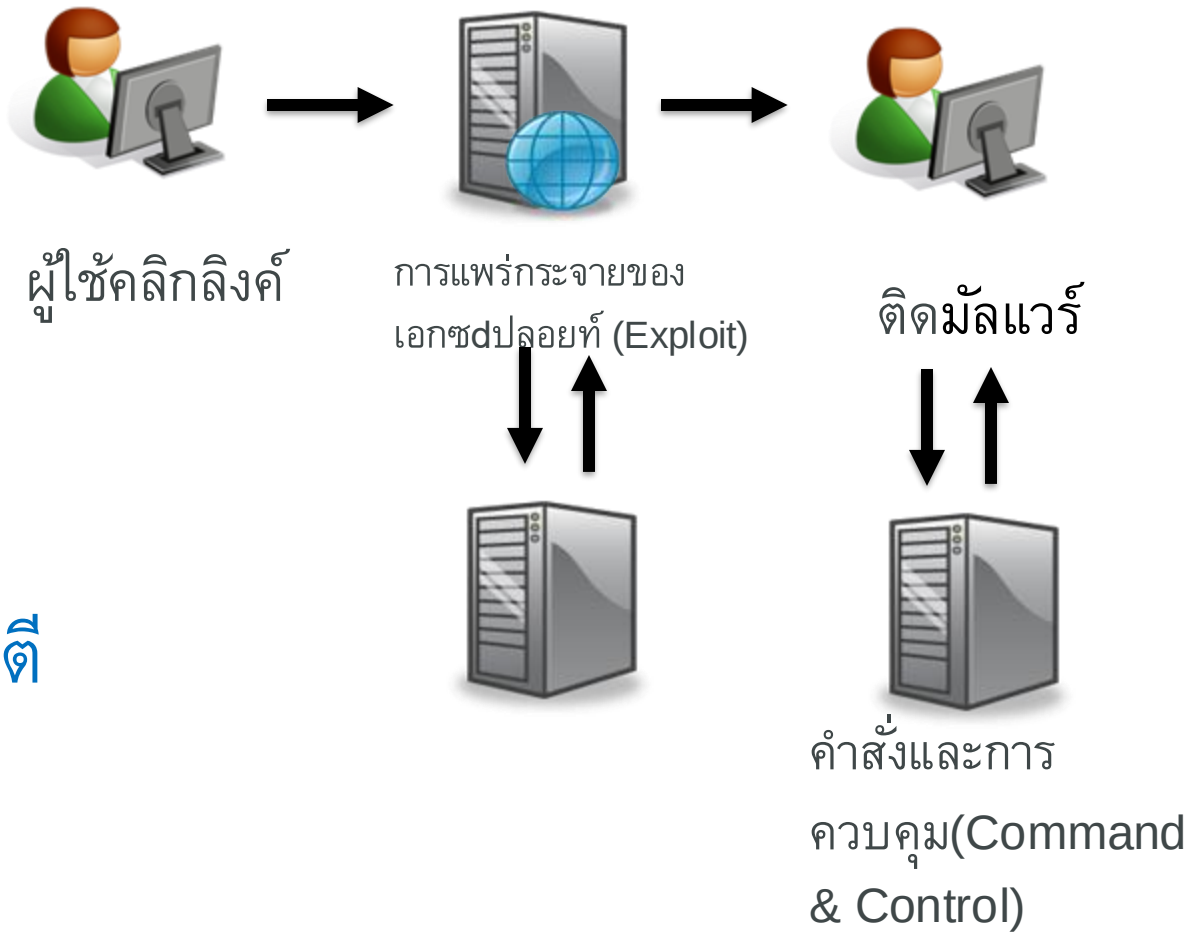
Storage

- modify or delete the contents of your shared storage
- read the contents of your shared storage

Other

- download files without notification
- run foreground service
- access Bluetooth settings
- This app can appear on top of other apps
- run at startup
- Google Play license check
- view network connections
- prevent phone from sleeping
- view Wi-Fi connections
- receive data from Internet
- measure app storage space
- control vibration
- Google Play billing service
- connect and disconnect from Wi-Fi
- have full network access
- retrieve running apps
- change network connectivity
- Play Install Referrer API
- pair with Bluetooth devices

รู้หรือไม่ว่าคนร้ายทำงานอย่างไร?



เทคนิคการโจมตี

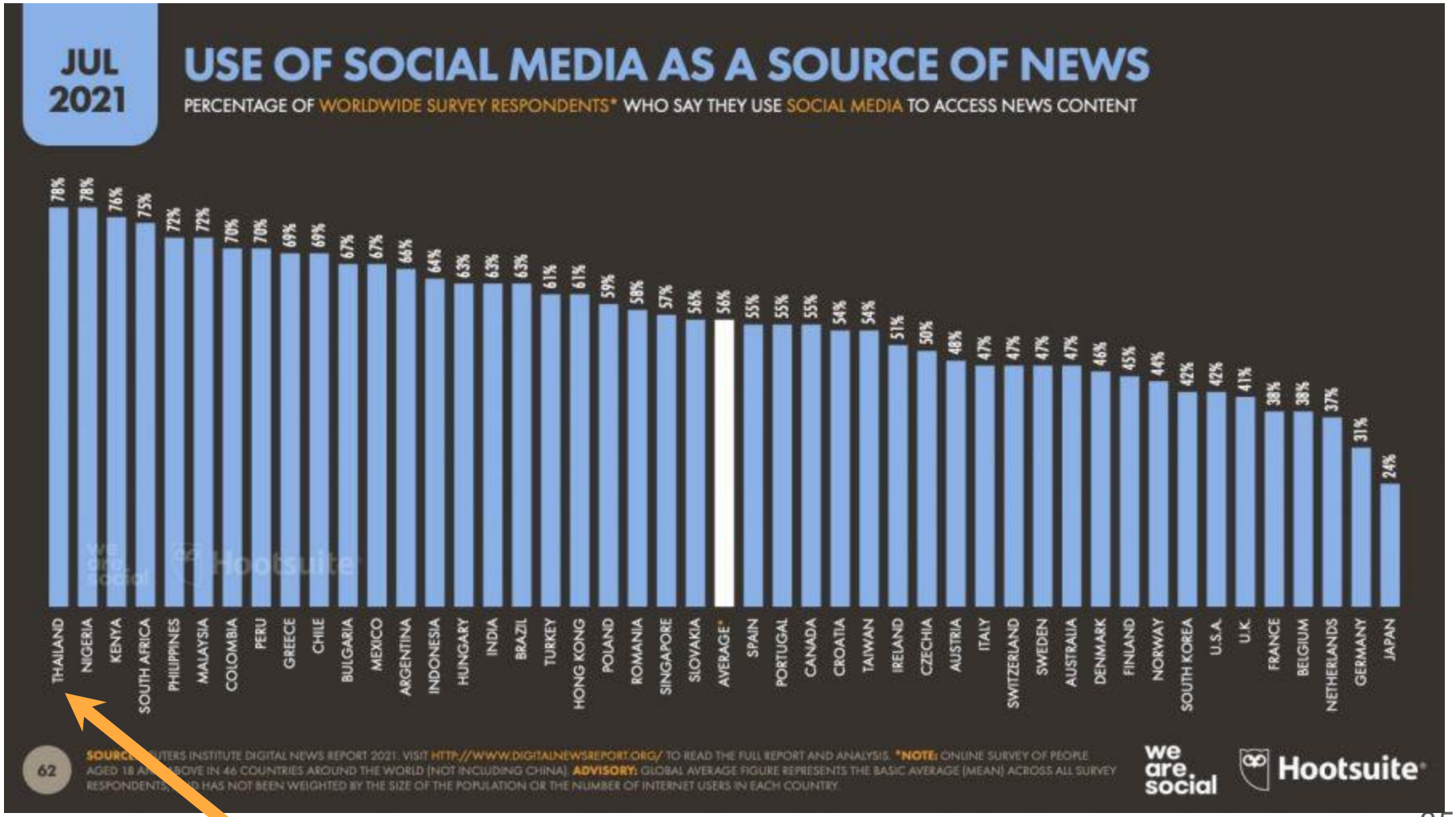
ยอดนิยม

ทำไมความตระหนักรู้เรื่องความปลอดภัยจึงสำคัญ

การฝึกอบรมสร้างความตระหนักรู้เรื่องความปลอดภัย (security awareness training) มีความสำคัญต่อทุกคน เพราะ

- สามารถหลีกเลี่ยงปัญหาหรือผลกระทบได้อย่างมีนัยสำคัญ หากคนในองค์กรได้รับการฝึกอบรม ด้านความปลอดภัยล่าสุดที่ดีขึ้น และจำนวนมากขึ้น
- การฝึกอบรมทำให้มั่นใจว่าผู้คนในระดับต่าง ๆ มีความรู้ที่ถูกต้องในการปฏิบัติหน้าที่ได้อย่างปลอดภัย ขณะใช้ระบบทั้งส่วนตัวและส่วนรวม
- การฝึกทักษะความตระหนักรู้ทำให้แน่ใจว่าทุกคนในทุกระดับรู้ว่าควรระวังอะไร

คนไทยใช้โซเชียลมีเดียในการอัพเดทข่าว เป็นอันดับ 1 ของโลกในปี 2564



https://www.bangkokbiznews.com/tech/950958

เทรนด์ภัยไซเบอร์ 2564

- Abusive Content

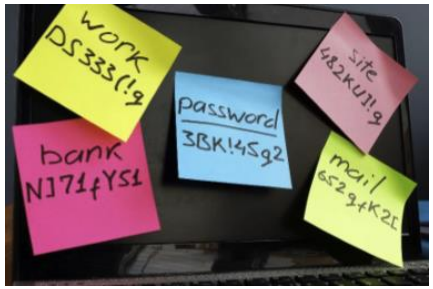
  (เนื้อหาที่ไม่เหมาะสม)
- Fraud (การฉ้อโกง)
- Information Security

  (ความปลอดภัยของข้อมูล)
- Intrusions (การบุกรุก)
- Malicious Code

  (มัลแวร์ หรือโปรแกรมที่สร้างขึ้นมาเพื่อประสงค์ร้ายต่อคอมพิวเตอร์)

https://www.salika.co/2021/10/07/9-trends-cyber-security-trend-micro/
https://www.thaicert.or.th/statistics/statistics.html

ความตระหนักรู้ด้าน Cybersecurity



- ควรมีการแยก User ใช้งานกันของแต่ละบุคคล
- ควร Logout เมื่อไม่อยู่หน้าเครื่องคอมพิวเตอร์
- ควรติดตั้ง Anti-Malware และมีการ update อย่างสม่ำเสมอ
- มีการ Update Patch ระบบปฏิบัติการ(OS)
- มีการ Update Version ของโปรแกรมบนเครื่อง
- ไม่ควรจด Password และติด Password ไว้ที่หน้าจอ
- มีการใช้ Password ที่ดี และ ไม่ควรบอก Password แก่ผู้อื่น